NORMATIVE SPECIFICATION · WORKING DRAFT V1

QKEC-1

A reference construction of the QuietKey provisioning entropy conditioner, with cross-checked test vectors. Production strength is **24 words / 256-bit only** for every factor (Seed-A, Seed-B, Seed-C) and for the 256-bit A2 key; the 12-word length survives solely as a primitive/standards unit-test vector, not a product mode. This is a candidate to be frozen only after independent cryptographic review and hardware source characterization — not a closed decision.

> PROJECT STATUS — PROVISIONING-ONLY, REVIEW PENDING
>
> Seed generation is a **provisioning** function (acquire & verify all four provisioning secrets), not a daily mode. QKEC-1 conditions four separate fresh acquisitions — **Seed-A, Seed-B, Seed-C, and the 256-bit A2 key** — each with its own purpose tag; none is derived from another or from a shared master. The vectors below are reference computations cross-checked against BIP-39 (Trezor), RFC 5869, and the canonical seed constant (evidence levels 1–2). The construction must not be frozen until an independent cryptographic review and a real SP 800-90B characterization of each hardware source exist. Card algorithm support must be bench-confirmed, not inferred from API names.

SPEC ID	PRIMITIVES	SHA-3 / KMAC	OUTPUT	VECTORS	DATE
QKEC-1	SHA-256 · HKDF-SHA-256	not used	256-bit ENT (24w)	reference (L1–2)	2026-08-17

---

01 SCOPE

One conditioner, two modes, no exotic primitives

QKEC-1 turns physical and hardware entropy into the 256-bit output for the four provisioning secrets of the QK2 wallet — the selected native `wsh(sortedmulti(2, A, B, C))` P2WSH 2-of-3 policy: **Seed-A, Seed-B, Seed-C** (each a BIP-39 entropy `ENT`) and the 256-bit **A2** key. Each is a *fresh, independent acquisition* carrying its own purpose tag; **none is derived from another or from a single master**. It defines two modes that must never be blurred: **Mode A** (externally verifiable pure dice) and **Mode B** (a domain-separated hybrid of ≥2 independent hardware sources plus optional dice), plus an experimental third method (CloakGrid, §04). Everything here is deterministic and reproducible from the inputs.

A2 is not a BIP-39 seed and not a Bitcoin signing key — it is a 256-bit random key used to decrypt Recovery Document A1, generated fresh at provisioning and *duplicated onto both cards B and C* (then wiped from the terminal). It is conditioned to 256 bits with its own purpose tag but is emitted as raw key bytes, not a mnemonic.

Out of scope: the card-authentication ceremony and minimal card protocol (GET_A2 / SIGN / PROVISION / RETIRE), the A1 AEAD payload format, and the card-bus transport (inside the trusted-terminal boundary in v1 — **no bespoke secure channel**) are separate protocols. QKEC-1 fixes only how each of the four secrets is acquired and conditioned; where each secret is then written — the least-authority BIP-48 **account xprv at m/48'/0'/0'/2'** (with chain code and origin fingerprint) derived from

Seed-B → card B; the account xprv derived from Seed-C → card C; A2 → both cards; Seed-A entropy → encrypted into A1 — belongs to the provisioning protocol. The card applet implements **neither BIP-39 nor PBKDF2**: it receives the derived account xprv, never a mnemonic or root key.

> **PRIMITIVE CHOICE — AVOIDS SHA-3 (BUT STILL BENCH-CONFIRM)**
>
> QKEC-1 conditioning uses **SHA-256 and HMAC-SHA-256 (HKDF-SHA-256)** — with standard **HMAC-SHA-512** only for the BIP-39/BIP-32 seed and master derivation (§07) — avoiding SHA-3 / KMAC which many cards lack. The conditioner runs on the *terminal*; the card's only entropy duty is to supply a raw random sample (it does **not** generate Seed-B/Seed-C). This removes the SHA-3 dependency — but **"the API constant exists" is not "the card implements it with the needed performance and transient memory."** Card RNG quality, throughput, and health testing are Gate-B bench items, not assumptions; do not call all JavaCards compatible.

---

02 NOTATION & PRIMITIVES

Definitions used throughout

- `SHA256(x)` — 32-byte digest. `‖` — byte concatenation. All integers are **big-endian**.
- `HKDF-Extract(salt, ikm) = HMAC-SHA256(salt, ikm)` → 32-byte PRK (RFC 5869). `HKDF-Extract` is HMAC, a *vetted conditioning component* under NIST SP 800-90B §3.1.5.1.1.
- `HKDF-Expand(prk, info, L)` — RFC 5869; for `L ≤ 32` this is `HMAC-SHA256(prk, info ‖ 0x01)[0:L]`.
- `BIP39(ENT)` — the BIP-39 encoding: append the first `len(ENT)·8/32` bits of `SHA256(ENT)` as checksum, slice into 11-bit indices, map to the English wordlist.
- `ENT` — **32 bytes (24 words) in production.** `strength = 0x20`. The 16-byte / `0x10` (12-word)

length is retained *only* as a primitive/standards unit-test length (it exercises the BIP-39 checksum-width and strength-byte machinery); it is **not a selectable product mode** and no shipping factor uses it.

Fixed constants (copy exactly)

```
; DOMAIN SEPARATION lives in the per-secret salt (purpose ‖ ceremony-id).
; each secret is a FRESH acquisition; none is derived from another or a master.
PREFIX  = "QuietKey/QKEC-1"          ; 15 bytes
        = 51756965744b65792f514b45432d31
salt    = SHA256(PREFIX ‖ purpose ‖ ceremony-id)   ; 32 bytes — per-secret, per-ceremony
purpose ∈ { "Seed-A" 536565642d41  → Seed-A entropy (encrypted into Recovery Doc A1)
            "Seed-B" 536565642d42  → Seed-B entropy (Key Card B, provisioned as account xprv)
            "Seed-C" 536565642d43  → Seed-C entropy (Emergency Card C, provisioned as account xprv)
            "A2"     4132          → 256-bit A2 (raw key, NOT a mnemonic; duplicated to B and C) }
ceremony-id = 16-byte per-provisioning nonce   ; binds every output to THIS ceremony
OUTPUT_INFO = "QuietKey/256-bit-output"   ; 23 bytes — the ONE fixed HKDF-Expand info
        = 51756965744b65792f3235362d6269742d6f7574707574
VERSION = 0x01
; source-record type tags
SRC_TRNG_SOC=0x01  SRC_TRNG_CARD=0x02  SRC_DICE=0x03  SRC_COIN=0x04  ; 0x05+ reserved
```

---

03 MODE A

Verifiable pure dice — byte-identical to the ColdCard convention

The entropy is `SHA256` over the raw ASCII string of die faces. This matches ColdCard's `rolls.py` / `rolls12.py` and the SeedSigner dice family exactly, so any user can reproduce the mnemonic on an independent tool. It deliberately does **not** use Ian Coleman's *Dice* mode (which remaps 6→0 and would produce a different mnemonic from identical rolls).

```
function mode_A(rolls, words):        ; rolls: string of chars '1'..'6' (0x31..0x36), no separators
    require every char ∈ {'1','2','3','4','5','6'}   ; reject invalid keys at ENTRY, never filter
    strength = (words == 12) ? 16 : 32
    dd  = SHA256(ascii(rolls))               ; 32 bytes
    ENT = dd[0 : strength]                    ; 12w keeps first 16 bytes; 24w keeps all 32
    return BIP39(ENT)
```

Mandatory gates

GATE	RULE	RATIONALE
Production strength	**`24 words / 256-bit only`**	The single shipping strength for Seed-A/B/C and (as raw bytes) A2. 12 words is a unit-test length only — never offered to a user.
Roll count	**`exactly 100 (24w)`** `· 50 (12w unit-test only)`	99 rolls ≈ 255.91 bits — **under 256**; require **exactly 100** (≈258.5 bits) for an honest 256-bit claim (four secrets × 100 = **400 rolls per kit**). The 50-roll floor applies only to the 12-word unit-test vector, not to any product path.
Face bias	`reject if any face > 30% of rolls`	A **gross-anomaly check only** (ColdCard `BAD_DICE`). It does *not* prove fair dice or any min-entropy level; its false-positive/false-negative behaviour must be measured, not assumed.
Empty / degenerate	`reject SHA256("")=e3b0c442…`	ColdCard flags this as a "known wallet".
Live counter	`gate "continue" on roll count, echo each key`	A missed roll must be visible; never silently swallow input.

OPERATOR WARNING (MUST DISPLAY)

In Mode A the on-screen roll string and its `SHA256` digest are **wallet-equivalent secret material**. Anyone who observes the

> rolls can reproduce the seed. Do not photograph; do not roll under observation. This is the price of external verifiability — for observer-resistance, use Mode B.

---

04 MODE B

Domain-separated hybrid conditioner

Each source is drawn and health-tested independently, then framed as a length-prefixed TLV record. The records are concatenated in canonical order into `IKM`, extracted with HMAC-SHA-256 under the per-secret salt, and expanded to exactly 32 bytes. Concatenation-into-HMAC (never XOR) is what makes user/dice entropy *additive-only* — see §05.

Source record & canonical IKM

```
record(type, value) = type(1 byte) ‖ len(value)(2 bytes, BE) ‖ value

IKM = VERSION(0x01) ‖ record(t₁,v₁) ‖ record(t₂,v₂) ‖ …
      ; records sorted ASCENDING by type; each type appears AT MOST once
      ; multiple draws from one source are concatenated BEFORE framing
      ; Mode B MUST include ≥2 independent hw sources: 0x01 AND 0x02. Dice (0x03) optional.
      ; each hardware source contributes ≥ 32 bytes AFTER health tests
```

Extract → expand

```
salt = SHA256("QuietKey/QKEC-1" ‖ purpose ‖ ceremony-id)   ; purpose ∈ {Seed-A,Seed-B,Seed-C,A2}
PRK  = HKDF-Extract-SHA256(salt, IKM)       = HMAC-SHA256(salt, IKM)      ; 32 bytes
info = OUTPUT_INFO = "QuietKey/256-bit-output"     ; the ONE fixed expand info — purpose already bound in the salt
ENT  = HKDF-Expand-SHA256(PRK, info, 32)     = HMAC-SHA256(PRK, info ‖ 0x01)[0:32]     ; always 32 bytes (256-bit only)
```

```
return BIP39(ENT)                         ; Seed-A/B/C only; A2 returns the 32 raw ENT bytes (no BIP39)
```

The per-secret `salt = SHA256("QuietKey/QKEC-1" ‖ purpose ‖ ceremony-id)` is what carries **domain separation**: it binds the extraction to QKEC-1, to one of the four **purpose tags** (Seed-A / Seed-B / Seed-C / A2), and to *this* provisioning ceremony, so the same source bytes drawn for a different secret or a different ceremony yield unrelated output. The `info` string is a single fixed constant (`"QuietKey/256-bit-output"`); the purpose no longer lives in `info`. This is what keeps the four secrets independent *even if* an implementer were tempted to reuse a source pool — but the normative rule is stronger: each secret **MUST** use a *fresh, independent acquisition*, and none may be derived from another or from a single master (**never expand one wallet master into all four**).

> **ACQUISITION ORDER (CLOSES THE ADAPTIVE CHANNEL)**
>
> The device MUST draw all hardware source bytes and compute the dice digest **before** conditioning, and MUST never display any raw source bytes or `PRK` / `IKM` — only the final wallet fingerprint (§07). This removes any "observe one source, then choose another" adaptive advantage.

Experimental method — CloakGrid (no security claim yet)

CloakGrid is an **experimental third provisioning method** for verifiable physical entropy, alongside Mode A (dice) and Mode B (hybrid). The user arranges **64 unique physical tiles** into a sequence; the ordering is captured as a *permutation* and fed to the conditioner as a physical source record. A permutation of 64 distinct items carries $\log_2(64!) \approx 296$ bits — ample headroom above the 256-bit target — so the design intent is a pure-physical, HWRNG-independent source in the spirit of Mode A dice, but faster to enter.

> **EXPERIMENTAL — NOT A SHIPPABLE SOURCE**
>
> CloakGrid carries **no security claim** and MUST NOT be offered as a production provisioning path until *each* of the following is

> independently validated: tile **acquisition** (how the ordering is captured — camera/OCR or manual), the permutation-to-bytes **extractor** (canonical, reproducible, no modular bias), residual **bias** characterization, **OCR** error and mis-read behavior, **loss/duplication detection** (missing or repeated tiles must fail loudly, not silently shrink the permutation), and **human trials** for real entry error rates. Until then it is a research item, held to the same domain-separation and reachability rules as every other source, and it does not relax the ≥2-source Mode B policy.

---

05 SECURITY INVARIANT

The additive property — and the assumptions it rests on

> CORRECTED CLAIM — DO NOT ASSERT ENTROPY SUMS
>
> An earlier version claimed the output min-entropy is at least the *sum* of the unknown sources' entropies. **That is not justified**: it requires independence and non-correlation assumptions that concatenation-into-HMAC does not by itself establish. The honest claim is: *the output is computationally unpredictable if **at least one** contributing source is independent, uncompromised, and non-adaptively acquired with sufficient entropy, and the conditioner is sound.*

What HMAC does give. In `PRK = HKDF-Extract(salt, IKM) = HMAC-SHA256(salt, IKM)` the `salt` is the HMAC *key* and `IKM` is the HMAC *message*; HKDF-Extract is invoked here as a randomness **extractor** over the prefix-free TLV encoding `IKM`, not as a general PRF over it. RFC 5869 is explicit that the extractor's guarantees rest on assumptions about the *input distribution* and the *independence* of the source material, and the "one good source suffices" robust-combiner reading remains a candidate property subject to independent cryptographic review. Under those assumptions, an attacker who fully knows some sources but not others still cannot predict `PRK` without the unknown input. Concatenation (not XOR) is what makes this hold: a known source aligned with an unknown one cannot *cancel* it. So a single stuck or backdoored source cannot drag the output below what the remaining good source provides — but this is a **"one good source suffices"** guarantee, not an entropy-summation guarantee, and it depends on the acquisition being non-adaptive (sources drawn and committed before any is revealed).

Illustrated (not proven) by the vectors: in TV-B1 vs TV-B2 the SoC and card sources are held identical and fully known; adding only the dice record changes all 32 bytes of `ENT`, showing the dice contribution cannot be predicted or cancelled by the known sources. (TV-B1/TV-B2 are computed under the retired HMAC-SHA512 conditioner — see §08 — and are retained only as a regression fixture; the structural property is hash-independent and holds identically under the production HKDF-SHA256 construction.) Independence of the real hardware sources remains an assumption to be justified per the QK2 threat model.

---

06 HEALTH TESTS

Per-source, at boot and continuous, fail loud

Real RCT/APT health testing belongs to the *raw noise source* and presupposes a documented symbol model, window sizes, and an assessed min-entropy `H` (bits/sample) — a hardware-characterization deliverable — with cutoffs at false-positive rate $\alpha = 2^{-20}$, per NIST SP 800-90B §4.4. When a source exposes only an already-conditioned 32-byte API draw, the terminal performs only **gross** failure checks (timeout, all-zero, identical-repeat, impossible status, stuck-at) and **MUST NOT** claim SP 800-90B compliance from a repetition-count or adaptive-proportion test on that conditioned result. The parameters below describe the raw-source regime and remain *unvalidated* until each source is characterized.

TEST	PARAMETER	ACTION ON FAILURE

Repetition Count (RCT)	`cutoff C = 1 + ⌈20 / H⌉`	≥ C identical consecutive samples ⇒ exclude source
Adaptive Proportion (APT)	`window W = 512 (non-binary) / 1024 (binary); C from binomial(W, 2⁻ᴴ, α)`	first sample recurs > C times in window ⇒ exclude source
Stuck-at (cheap)	`≥ 5 distinct byte values per 32-byte draw`	ColdCard `len(set)>4` catch for a constant source

LOUD EXCLUSION, THEN BLOCK

A failed source is shown as **failed** on screen and excluded from `IKM`. If fewer than the two required independent hardware sources remain, seed generation is **blocked** — never a silent single-source continue. Assert (do not `#ifndef` -check) that each source peripheral is live at boot; fail closed if not. Health tests catch statistical failure but *not* a well-formed backdoor — which is exactly why QKEC-1 requires ≥2 designated sources as a defense-in-depth policy (one sound independent source suffices for the security claim; their independence must be justified per the threat model, not assumed from two API calls).

Three claims that do NOT imply one another

QKEC-1 keeps three separate properties separate. Satisfying one says **nothing** about the others; conformance must evidence each on its own.

CLAIM	WHAT IT MEANS	WHAT IT DOES NOT ESTABLISH
Reproducibility	A verifiable pure-dice (Mode A) or recorded-source run recomputes the identical output on an independent tool.	Says nothing about how much entropy the input had, nor whether the intended source was used.
Health testing	RCT/APT/stuck-at flag a statistically defective source at run time.	Cannot prove min-entropy, cannot detect a well-formed backdoor, and cannot prove the tested bytes are what actually reached the conditioner.

Source independence	The designated sources are physically/architecturally uncorrelated, justified per the threat model.	Not implied by "two API calls exist", by passing health tests, or by reproducibility.

Build- & source-reachability testing (the ColdCard 2026 lesson)

> **PROVE THE INTENDED SOURCE ACTUALLY REACHES THE CONDITIONER**
>
> Statistical health tests operate on whatever bytes they are handed; they cannot prove those bytes came from the intended HWRNG rather than a constant, a stale buffer, or a substituted path. QKEC-1 therefore requires **end-to-end build/source-reachability evidence**, not health tests alone:
>
> - **Build-time symbol/reachability checks** — the acquisition symbols for each designated source are present and reachable in the shipped image (no dead-stripped or stubbed path); fail the build otherwise.
> - **Instrumented manufacturing tests** — a factory build that taps the raw source at the point of acquisition and confirms live, varying data per source before the conditioner.
> - **Deterministic fault injection** — force each source to a known-bad/constant state and confirm the run *blocks loudly* (never silently substitutes or continues).
> - **Reproducible pure-physical mode** — a Mode A / recorded-source run whose output is independently recomputable, giving an auditable path that needs no trust in the HWRNG at all.
>
> These are provisioning-security deliverables (a manufacturing/build concern), distinct from the user-facing gates above and still *unvalidated*.

---

07 DERIVATION & DISPLAY

ENT → mnemonic → seed → fingerprint

Both modes end at the same standard path. Hard-code the constants; expose no options.

Both modes end at the same standard path. Hard-code the constants; expose no options.

```
mnemonic    = BIP39(ENT)                              ; English wordlist only
seed(64B)   = PBKDF2-HMAC-SHA512(2048 rounds, dklen=64,
                  password = NFKD(mnemonic words, space-joined),
                  salt     = NFKD("mnemonic" ‖ passphrase))    ; NFKD on BOTH inputs
master      = HMAC-SHA512("Bitcoin seed", seed)       ; IL=master key, IR=chain code
fingerprint = HASH160(compressed master pubkey)[0:4]    ; BIP-32 master fingerprint
display     = uppercase, two 4-hex groups              ; e.g. 2FAE-9711
```

The 2048 rounds are fixed forever — never the ColdCard/Coleman user-selectable-rounds footgun, which silently breaks compatibility with every other wallet. The fingerprint is shown after reconstruction so a swapped Recovery Document or mistyped roll is caught before any funds move.

---

08 TEST VECTORS

Every value computed & cross-checked (evidence level 1–2)

The reference implementation self-checks against four independent published constants before emitting any vector — so these are reference conformance targets (evidence level 1–2), not hand-written hex. They are cross-check computations, not a validated implementation.

The suite is **not** uniform: each vector belongs to one of three classes, because several deliberately exercise the primitive with inputs the ceremony must never accept. **Primitive/unit** vectors (TV-A0, TV-A1) bypass the ceremony gates on purpose — the current primitive must reproduce them, but the ceremony parser MUST NEVER accept them (single-face rolls fail the >30% bias gate). The Mode B vectors (TV-B1, TV-B2, TV-B3) are a **retired-construction regression fixture** computed under the superseded HMAC-SHA512 conditioner (their all-zero / all-ff source streams also fail the §06 health tests); the **production HKDF-SHA256 Mode B** vectors are the positive **TV-MB-A/B/C/A2** set (embit-cross-checked). **Negative end-to-end** vectors are inputs the ceremony MUST reject. **Positive end-to-end** vectors (TV-A2) pass every gate. Do not read the primitive/unit vectors as ceremony-conforming.

> REFERENCE ANCHORS (INDEPENDENT CROSS-CHECKS)
>
> **BIP-39 encode** → Trezor all-zero: `00…(16B) → abandon×11 about`. **PBKDF2 seed** → canonical empty-passphrase constant `5eb00bbddcf06908…ce9e38e4`. **HKDF** → RFC 5869 Test Case 1 (`PRK=077709362c2e32df…`, `OKM=3cb25f25faacd57a…`). **secp256k1** → `abandon…about` root fingerprint `73c5da0a`.

MODE A — VERIFIABLE DICE

```
TV-A1  [PRIMITIVE/UNIT — ceremony MUST NOT accept]  12 words · 50 rolls = "1"×50
  SHA256(rolls) = 3dac51a65ec9fcfc409a1b5f1defe92ba723843118ea511971ab46b36859495f
  ENT           = 3dac51a65ec9fcfc409a1b5f1defe92b
  mnemonic      = diet glad hat rural panther lawsuit act drop gallery urge where fit
  fingerprint   = 65FB-43FE
  ; single-face rolls FAIL the >30% bias gate: primitive reproduces these bytes, ceremony MUST reject the rolls

TV-A2  [POSITIVE end-to-end — passes every gate]  24 words · 100 rolls = "123456"×16 ‖ "1234"
  SHA256(rolls) = e56403e8522ddeae1b44a1e8148b1ba4d3b4c626ccf20980056eedcc7e0c0f35
  ENT           = e56403e8522ddeae1b44a1e8148b1ba4d3b4c626ccf20980056eedcc7e0c0f35
  mnemonic      = tornado cactus wheel picture target finish home neither trend picture
                  shoulder endless deputy glide open oxygen another ability forum swear
                  side alcohol devote random
  seed(pp='')   = (regenerated; see fixtures)
  fingerprint   = 2FAE-9711

TV-A0  [PRIMITIVE/UNIT — ceremony MUST NOT accept]  guard: SHA256("") = e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495
                  primitive reproduces the digest; ceremony MUST reject (empty / known wallet)
```

MODE B — HYBRID · PRIMITIVE/UNIT · RETIRED CONSTRUCTION (HMAC-SHA512): THE PRK/ENT/FINGERPRINTS BELOW WERE COMPUTED UNDER THE SUPERSEDED SHA-512 EXTRACT/EXPAND AND ARE RETAINED ONLY AS A REGRESSION FIXTURE. PRODUCTION QKEC-1 USES HKDF-SHA256 WITH SALT=SHA256("QUIETKEY/QKEC-1"‖PURPOSE‖CEREMONY-ID) AND FIXED INFO "QUIETKEY/256-BIT-OUTPUT" — THE PRODUCTION HKDF-SHA256 MODE B VECTORS ARE GIVEN IMMEDIATELY BELOW AS TV-MB-A/B/C/A2. (ILLUSTRATIVE SOURCES SOC=00×32, CARD=FF×32 ALSO FAIL THE §06 HEALTH TESTS, SO THE CEREMONY MUST NOT ACCEPT THESE SOURCE RECORDS.)

```
TV-B1  [PRIMITIVE/UNIT — ceremony MUST NOT accept]  24 words · sources {soc, card}   ; no dice
  IKM = 0101002000000000000000000000000000000000000000000000000000000000000000
        020020ffffffffffffffffffffffffffffffffffffffffffffffffffffffffffffffff
  info= 51756965744b65792f514b45432d312f736565642d410020
  PRK = 03ad688b2caabf64f189fb1d9bd00f515e4efefb0a8d83072dae4b9a49b4de40
        9d2c0bfae11046a1e570f497706b3e9beafe807e303f532fb5770d6b573afe33
  ENT = f66adf897b48e21dfa99ba1f259bfa791c3b0568c3b3fc482eafd08169456612
  mnemonic    = wait finger time walk mixed auction tuna dance busy coast write vendor
                senior live perfect island wisdom door program patient bird pencil
                obscure enlist
  fingerprint = 9B08-54E3

TV-B2  [PRIMITIVE/UNIT — ceremony MUST NOT accept]  24 words · sources {soc, card, dice}   ; dice = SHA256 of TV-A2 rolls (0
  IKM = …(TV-B1 IKM) ‖ 03 0020 e56403e8522ddeae1b44a1e8148b1ba4d3b4c626ccf20980056eedcc7e0c0f35
        ; dice record = type(03) ‖ len(0020) ‖ SHA256(rolls)
  PRK = (regenerated; see fixtures)
  ENT = 49956b011c82fda56ac57e0ea86b1bfcb19d26c86c30494e372b2660983b0cc8
  mnemonic    = (regenerated; see fixtures)
  fingerprint = 72A1-4AB8
  ; vs TV-B1: adding only the dice record changes all 32 ENT bytes (invariant §05)

TV-B3  [PRIMITIVE/UNIT — ceremony MUST NOT accept]  12 words · sources {soc, card}   ; same sources as TV-B1, strength 0x10
  info= 51756965744b65792f514b45432d312f736565642d41 00 10
  ENT = 544647aa707e926482ccc92a067d566d
  mnemonic    = february cram tunnel thought truck crane arctic odor claw crop few swarm
  fingerprint = 6A9E-A4D6
  ; retired construction: this demonstrated strength-byte separation. Production HKDF-SHA256 separates via the salt (purpose
```

MODE B — PRODUCTION HKDF-SHA256 · POSITIVE END-TO-END: THE CANONICAL CONSTRUCTION (VERSION‖TLV IKM, PER-SECRET SALT =

SHA256("QUIETKEY/QKEC-1"‖PURPOSE‖CEREMONY-ID) , FIXED INFO = "QUIETKEY/256-BIT-OUTPUT" , HKDF-SHA256, 32-BYTE OUTPUT). SOURCES ARE DETERMINISTIC TEST STAND-INS FOR REAL RNG SAMPLES (V1 §4.3: SAMPLE = SHA256("QK2-QKEC1-TESTVECTOR/V1/"‖SOURCE-NAME‖"/"‖PURPOSE) , FRESH PER PURPOSE) AND THE CEREMONY-ID IS A FIXED TEST CONSTANT 000102…0F (PRODUCTION DRAWS A FRESH 16-BYTE NONCE PER PROVISIONING). REPRODUCED BY THE COMPANION VERIFIER QKEC1_MODEB_V1.PY , WHOSE HKDF-SHA256 PASSES RFC 5869 TC1; EVERY MNEMONIC BELOW WAS INDEPENDENTLY CROSS-CHECKED AGAINST EMBIT (SEED + MASTER FINGERPRINT MATCH, CHECKSUM VALID). THESE ARE CONDITIONER REFERENCE VECTORS — *NOT* THE CANONICAL WALLET SPINE (THAT IS THE MODE A 100-ROLL CEREMONY).

```
TV-MB-A  [POSITIVE — Seed-A purpose]  24 words · sources {terminal, card-B, card-C}
  ceremony-id = 000102030405060708090a0b0c0d0e0f            ; TEST constant
  src 0x01 terminal-hwrng = 1b255af36f5c09e37312b86c522c1bf93d573f1fc5397b54b0a58415809ee59c
  src 0x02 card-B-rng     = 7a5116fe16ac3c9f6d97f42d0f41318d6954ff987c5a22b42b21ca8b9d421d65
  src 0x03 card-C-rng     = 27f9d2e6fec087350478d3eebbfea8bff6b341e7c344441b6a6d9b554f59e4c2
  IKM  = 01 0100201b255af36f5c09e37312b86c522c1bf93d573f1fc5397b54b0a58415809ee59c
            0200207a5116fe16ac3c9f6d97f42d0f41318d6954ff987c5a22b42b21ca8b9d421d65
            03002027f9d2e6fec087350478d3eebbfea8bff6b341e7c344441b6a6d9b554f59e4c2   ; 106 bytes = 0x01 ‖ 3×[id·0020·32B]
  salt = 45032bc1c5b2580247a5624aea53dee4b28d8e920b424edd68db3434064cf637   ; SHA256("QuietKey/QKEC-1"‖"Seed-A"‖ceremony-id)
  PRK  = 6e11495440ab46c296c7182e34c0bbf9a986fa2c9157dd7adc7f9678b22d5491
  ENT  = 6a87d26de835946593d59e4452eebe96c44a9330b0596050a01386bd80d31f3c
  mnemonic    = hedgehog direct opinion spare flock crazy exercise record dust number quick
                collect dwarf end security arctic gate lunar agent aspect submit hat language month
  fingerprint = FB5C-F734   ; embit agrees: seed + master fp match, checksum valid

TV-MB-B  [POSITIVE — Signer-B purpose]  24 words · same three sources, drawn fresh for "Signer-B"
  ENT  = (see qkec1_modeb_v1_vectors.json)
  mnemonic    = milk label other say purchase morning shell fragile peasant rocket tail village
                bundle link copy cash female wool opera nose buzz visit bulb damp
  fingerprint = 06A5-343E   ; embit ✓

TV-MB-C  [POSITIVE — Signer-C purpose]  24 words · same three sources, drawn fresh for "Signer-C"
  mnemonic    = effort clock alcohol wagon follow fee salmon absurd image dice fox service
                notice ghost gather force super canoe onion screen crane sight soft famous
  fingerprint = 9B4E-B9B2   ; embit ✓

TV-MB-A2  [POSITIVE — A2 purpose]  32-byte document key (NOT a BIP39 seed / not a Bitcoin key)
  A2   = 58ae66c23933f8dd1733dc2a141040ceec436c3b47df903368a98900fb743f47
  ; all four purpose outputs are distinct — the same three sources drawn under four purpose tags do not collide
```

09 CONFORMANCE

What an implementation must do to be QKEC-1

1. The §08 suite is split by class and each class carries a different obligation: for the **primitive/unit** vectors (TV-A0, TV-A1 — inputs that deliberately bypass the ceremony gates) the primitive **`MUST`** reproduce the stated bytes exactly, *and* the ceremony parser **`MUST NEVER`** accept them; the Mode B vectors (TV-B1, TV-B2, TV-B3) are a **retired HMAC-SHA512 regression fixture** that only the retired path reproduces, while the production HKDF-SHA256 Mode B vectors are the positive **TV-MB-A/B/C/A2** set the current primitive **`MUST`** reproduce (embit-cross-checked, RFC 5869 TC1-anchored); for the **negative end-to-end** vectors the ceremony **`MUST`** reject the input; for the **positive end-to-end** ceremony vectors (TV-A2) the ceremony **`MUST`** pass every gate and reproduce the result. Firmware and the host verifier remain bit-identical on all current-construction computations.
2. **`MUST`** reject invalid dice keys at entry; **`MUST NOT`** filter after the fact.
3. **`MUST`** offer **24 words / 256-bit only** as a product strength (the 12-word length exists solely as a primitive/unit-test vector, never selectable). **`MUST`** enforce the Mode A gates (roll count **exactly 100**/24w — the 50-roll floor applies only to the 12-word unit test; 30% gross-anomaly check; empty guard) and require ≥2 *designated* sources in Mode B — with source independence *justified*, not assumed from two API calls.
4. **`MUST`** acquire **Seed-A, Seed-B, Seed-C, and A2 as four separate fresh acquisitions**, each conditioned under its own purpose tag bound into the salt (`purpose ∈ {Seed-A, Seed-B, Seed-C, A2} ‖ ceremony-id`); **`MUST NOT`** derive any secret from another or from a shared master. A2 is emitted as 32 raw key bytes (not a mnemonic) and duplicated to cards B and C.
5. **`MUST`** provide build/source-reachability evidence — build-time symbol/reachability checks,

instrumented manufacturing tests, deterministic fault injection, and a reproducible pure-physical mode — because health tests cannot prove the intended source reached the conditioner. Reproducibility, health testing, and source independence are **`separate`** obligations; none is evidence for another.

6. **`MUST`** define behaviour for interruption, restart, source timeout, and partial acquisition: a partially collected pool is discarded (never silently completed), and generation restarts cleanly with secrets wiped.
7. **`MUST NOT`** be frozen until an independent cryptographic review and a real per-source SP 800-90B min-entropy characterization exist.
8. **`MUST`** run SP 800-90B RCT + APT per source, exclude loudly, and block below two live sources.
9. **`MUST`** hard-code BIP-39 at 2048 rounds with NFKD on both inputs; **`MUST NOT`** expose selectable rounds.
10. **`MUST NOT`** display raw source bytes, `IKM`, or `PRK`; **`MUST`** display the fingerprint after reconstruction.
11. **`MUST`** treat the Mode A roll string / digest as secret; **`MUST`** show the observer warning.
12. **`SHOULD`** ship the stdlib-only verifier so users can independently reproduce Mode A (and audit Mode B if they record the source records).

> **REFERENCE VERIFIER**
>
> A self-contained Python-3 stdlib verifier (`qkec1.py`, ~400 lines, wordlist embedded) accompanies this spec for Mode A and the four anchors. The production **Mode B (HKDF-SHA256)** construction and the TV-MB-A/B/C/A2 vectors are reproduced by the companion generator `qkec1_modeb_v1.py`, which self-tests its HKDF-SHA256 against **RFC 5869 Test Case 1** and independently cross-checks every emitted mnemonic against **embit** (seed + master fingerprint); it emits `qkec1_modeb_v1_vectors.json`. Keep firmware math bit-identical to both and lock the vectors into CI drift-checks.

> **STILL OPEN (OUTSIDE QKEC-1)**

> Name the SoC HWRNG peripheral (unnamed in both QK2 PDFs) and complete its SP 800-90B min-entropy assessment to fix the real RCT/APT cutoffs; decide whether Mode B without dice is permitted for provisioning use or dice is mandatory at provisioning; and confirm the card RNG's on-card health testing. QKEC-1 fixes the construction; these fix its inputs.

`QKEC-1 · QuietKey Entropy Conditioner · working draft v1 · 2026-08-17`

All vectors produced by a pure-stdlib reference implementation cross-checked against the BIP-39 Trezor vector, the canonical empty-passphrase seed `5eb00bbd…`, RFC 5869 HKDF Test Case 1, and the secp256k1 root fingerprint `73c5da0a`. Mode A is byte-identical to ColdCard `rolls.py`. Companion to the QuietKey QK2 Blueprint.